

MiniPlasma Mitigations 5-20-2026

CVE-2020-17103 | cldfilt.sys LPE Zero-Day | Status: Unpatched | Microsoft: Investigating

No official patch available. Next Patch Tuesday: June 10, 2026. All mitigations below are imperfect — layer them accordingly.

Mitigation 1 — Unload the Cloud Filter Driver ☐

Effectiveness: High | Trade-off: Breaks OneDrive Files On-Demand

The cleanest technical mitigation. Removes the vulnerable component (`cldflt.sys`) from the attack surface entirely.

Command (elevated prompt required):

```
fltmc unload cldflt
```

When to use: Servers, build agents, developer workstations, or any endpoint that does not rely on OneDrive Files On-Demand.

Limitation: Breaks OneDrive sync on workstations where it is in use. Not practical for most standard corporate endpoints with OneDrive deployed. Verify impact before broad rollout.

Mitigation 2 — EDR Behavioral Detection ☐

Effectiveness: Medium-High | Trade-off: Detective only, not preventive

Monitor for anomalous activity patterns associated with MiniPlasma exploitation. Elastic Defend has confirmed detection coverage. Other major EDR vendors are publishing signatures.

Registry Keys to Monitor (ThreatLocker guidance — May 18, 2026):

```
\Registry\User\Software\Policies\Microsoft\CloudFiles\BlockedApps*  
\Registry\User\DEFAULT\Volatile Environment*
```

Key Behavioral Signals:

- `CfAbortHydration` API calls from any process other than OneDrive — this undocumented API has virtually no legitimate callers outside of the OneDrive client

- Anomalous registry write events to `HKU\ .DEFAULT` from non-SYSTEM / non-OneDrive processes (*Sysmon Event ID 13*)
- `SYSTEM` -token process spawned from a Medium or Low integrity parent with no corresponding authentication event (*Windows Event ID 4688*)
- Rapid, repeated Cloud Filter API calls from a single process — artifact of the race condition exploitation loop

Note: Reflective loader variants of the public PoC may bypass hash-based signatures. Prioritize behavioral detection over hash-matching alone.

Mitigation 3 — Block Known PoC Binaries by Hash ☐

Effectiveness: Low-Medium | Trade-off: Easily bypassed by recompile

EDR and AV vendors are publishing detection signatures for the compiled Nightmare-Eclipse binary distributed on GitHub.

Limitation: The full source code is publicly available. Any threat actor can recompile or wrap the exploit in a reflective loader, bypassing hash-based controls within minutes. Treat this as a speed bump, not a reliable control. Ensure your endpoint vendor's signature feed is current and covers both the original binary and common loader variants.

Mitigation 4 — Restrict Standard User Write Access to Placeholder Directories ☐

Effectiveness: Medium | Trade-off: May impact legitimate workflows

The exploit requires creating a cloud file placeholder in a location the Cloud Filter driver will accept. Tightening application allowlisting rules to limit where standard users can create files materially reduces the attack surface without fully eliminating it.

Implementation approach: Use application allowlisting (e.g., AppLocker, WDAC, or your EDR's file/path restriction policy) to restrict standard user write access outside of their own profile directories.

Mitigation 5 — Adjust IR Posture: Assume Phishing = SYSTEM ☐

Effectiveness: Operational | Trade-off: None

MiniPlasma is a single-step LPE from any standard user foothold. Combined with predecessor tools from the same researcher (UnDefend for Defender suppression, RedSun/GreenPlasma as alternative LPE paths), a successful phishing click on a corporate Windows endpoint should now be treated as a **presumed SYSTEM-level compromise** until forensically proven otherwise.

Recommended posture changes: - Escalate phishing incident severity to match assumed SYSTEM access - Scope lateral movement and credential dump activity from the point of initial access, not post-escalation - Apply regulatory notification trigger evaluation (GDPR 72h, SEC 4-day) at initial compromise, not after escalation is confirmed

Summary

#	Mitigation	Effectiveness	Breaks OneDrive?	Recommended For
1	Unload <code>cldflt.sys</code>	✓ High	Yes	Servers, build agents, non-OneDrive endpoints
2	EDR behavioral detection	☐ Medium-High	No	All endpoints — primary control
3	Block PoC binary hashes	☐ Low-Medium	No	All endpoints — supplementary only
4	Restrict placeholder dir writes	☐ Medium	No	Where allowlisting is feasible
5	Adjust IR posture	✓ Operational	No	All environments immediately

Primary recommendation: If OneDrive is deployed across your endpoints, Mitigation 1 is not broadly viable. **Mitigation 2 (EDR behavioral) is your primary control.** Ensure the ThreatLocker registry key monitors and `CfAbortHydration` hunt queries are active. Layer Mitigations 3 and 4 as depth.

TLP: WHITE | CVE-2020-17103 | ZD-040 | Author: C3PO | Created: 2026-05-20
Sources: BleepingComputer · SecurityWeek · ThreatLocker · gblock.app · Nightmare-Eclipse
GitHub
Next review: June 10, 2026 (Patch Tuesday)